

Cybersecurity & Digital Forensics

Internship Project Report

Comprehensive Security Assessment: Mediroza General Hospital (medirozahospital.com)

Prepared by: Muhammad Zain Ul Abiddin

Module 1: Patient Portal Reconnaissance & Initial Access

- **Target Environment:** Mediroza General Hospital Patient Portal (/patient/portal.php).
- **Initial Reconnaissance & Vulnerability Discovery:** Web server analysis indicated unprotected portal access points hosting patient files (including Pathology Report - S. Dlamini, P. Reddy, and E. Thompson).
- **Authentication Bypass Vector:** Unauthorized access was achieved by inputting an SQL injection payload (admin' --) directly into the username authentication parameter.
- **Outcome:** Successfully bypassed backend login controls to enter the protected dashboard and access encrypted laboratory records.

Module 2: Multi-File PDF Password Recovery & Analysis

Following portal access, three encrypted patient PDF reports were acquired and subjected to hash extraction and advanced cracking methodologies:

- **File 1: patient_report_1.pdf (Patient: Sipho Dlamini)**
 - **Lab Reference & Date:** LR-2024-1187 | 2024-11-04.
 - **Clinical Findings:** Whole blood analysis indicating an elevated White Cell Count ($11.8 \times 10^9/L$).

- **Cracking Strategy:** Processed via standard dictionary matching.
- **Recovered Password:** 123456
- **File 2: patient_report_2.pdf (Patient: Priya Reddy)**
 - **Lab Reference & Date:** LR-2024-1192 | 2024-11-05.
 - **Clinical Findings:** Lipid panel showing elevated Total Cholesterol (6.4 mmol/L), LDL Cholesterol (4.1 mmol/L), and Triglycerides (1.8 mmol/L).
 - **Cracking Strategy:** Evaluated via dictionary lookup.
 - **Recovered Password:** password
- **File 3: patient_report_3.pdf (Patient: Emily Thompson)**
 - **Lab Reference & Date:** LR-2024-1205 | 2024-11-06.
 - **Clinical Findings:** Serum analysis indicating low Haemoglobin (11.4 g/dL), low Ferritin (9 ug/L), and low Vitamin D (42 nmol/L).
 - **Hash Extraction:** Extracted via pdf2john.py:

Plaintext

```
$pdf$2*3*128*4294967292*1*32*326139306632613033663438633732363130616437326
4323130316137616538*32*5090fa0a5dba99cb97c9d140cd23119428bf4e5e4e758a41640
04e56ffa0108*32*58e03d692cf37b50b0b5eaa189fcbd372260a949c8992ad7b44fd13e2b
40c1f8
```

- **Technical Resolution:** Handled non-standard signed-integer iteration parameters (4294967292 / -4) and applied parallel combinatorial/hybrid rulesets to isolate the key.
- **Recovered Password:** !@#\$\$%^&

Module 3: Infrastructure Reconnaissance & Database Exposure

- **Target Application:** Mediroza CMS 1.4.2.
- **Directory Enumeration:** Scanning the web server revealed unprotected legacy directories and administrative paths (/old/ and /staff/) lacking proper access controls.
- **Exposed Artifacts:** An index listing exposing an internal database backup (mediroza_db_backup_2019.sql) and staff login scripts (login.php).

- **Extracted Database Contents (mediroza_db_backup_2019.sql):**
 - **Staff Table (staff):** Contained 30 structured records with full names, titles, corporate emails, phone numbers, South African national IDs, and exact monthly salaries in ZAR (e.g., Chief Pathologist Dr. Rajesh Naidoo earning R138,000/month; Medical Director Dr. Johan van der Merwe earning R160,000/month).
 - **Shareholders Table (shareholders):** Outlined corporate equity holdings, including ordinary and preferential shares distributed among top medical directors and holding entities like Cedar Health Holdings (15%) and the Reddy Family Trust (11%).

Key Recommendations

1. **Remediate SQL Injection Flaws:** Replace all vulnerable dynamic queries across authentication portals with parameterized statements (prepared statements) to block authentication bypass vectors like admin' --.
2. **Secure Directory Permissions:** Disable directory indexing globally on web servers and remove exposed legacy backups (mediroza_db_backup_2019.sql) from public-facing directories like /old/ and /staff/.
3. **Enforce Password Complexity:** Replace weak credentials (123456, password, and trivial strings) with robust alphanumeric and special-character requirements for both staff accounts and exported PDF documents.
4. **Upgrade Encryption Standards:** Migrate hospital document generation pipelines from legacy RC4/PDF 1.4 security wrappers to modern AES-256 (PDF 1.7) encryption frameworks.